대외비 2급

개발 및 응용시스템 보안 지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2012-02	2012-04-16	기존 변경요청서 [별지 제4호 서식] 삭제	조남인
2012-03	2012-04-26	[별지 제1호 서식] 제목 및 서식 개정 [별지 제4호 서식] 서식 개정	조남인
2013-01	2013-05-14	제31조 (기술적 취약점 통제) ③항 수정 [별지 제5호 서식] 서식 개정	조남인
2016-01	2016-09-26	제17조 (관리자용 및 개발자용 계정관리) ⑥항 추가 [별지 제6호 서식 추가]	조남인
2016-02	2017-01-16	법 제24조제1항 및 제3항에 따른 암호화 대상 명확화	조남인
2019-01	2019-10-22	제19조 (비밀번호 관리) ②항반기→분기	조남인
2020-01	2020-11-04	제6조 (정보시스템의 개발 요구분석 및 보안 적용) 수정 개발의 중요 단계→각 개발단계 별 제28조 (로그 및 모니터링) 수정 접속기록6개월-> 2년 제35조 (암호화 및 키관리) 추가 키변경 주기	조남인
2023-01	2024-01-08	제19조(비밀번호 관리) 제22조(응용서비스 접근통제) 제23조(화면 표시 제한)	조남인

목 차

제1조 (목적) 4
제2조 (적용범위) 4
제3조 (용어설명) 4
제4조 (책임과 역할) 4
제5조 (보안요구사항의 검토) 6
제6조 (정보시스템의 개발요구 분석 및 보안적용) 6
제7조 (입력 데이터 검증) 6
제8조 (프로그램의 처리절차) 7
제9조 (출력자료의 검증) 7
제10조 (환경 분리) 7
제11조 (운영 소프트웨어의 통제) 8
제12조 (프로그램 소스에 대한 접근통제) 8
제13조 (안전한 프로그래밍) 9
제14조 (외주 소프트웨어의 개발) 9
제15조 (의료기관 간 교환협정) 9
제16조 (진료 정보 등의 교환방법) 10
제17조 (관리자용 및 개발자용 계정관리) 10
제18조 (현업 사용자 계정 관리) 11
제19조 (비밀번호 관리) 11
제20조 (업무용 사용자 접근권한 관리) 12

제21조 (업무용 사용자 접근 및 사용 통제) **12**

제22조 (응용 서비스 접근통제) **12**

제23조 (화면 표시 제한) **13**

제24조 (의료정보시스템의 변경 통제 절차) **13**

제25조 (운영체제의 변경(PATCH UPDATE)에 따른 어플리케이션 검토) **14**

제26조 (응용시스템 백업) **14**

제27조 (응용시스템 복구) **14**

제28조 (로그 및 모니터링) **15**

제29조 (장애 관리) **15**

제30조 (가용성 및 무결성 확보) **15**

제31조 (기술적 취약점 통제) **16**

제32조 (암호화 요구) **17**

제33조 (암호사용에 관한 정책) **17**

제34조 (네트워크 암호화) **18**

제35조 (암호화 및 키 관리) **18**

제36조 (암호화 프로그램 관리) **19**

제37조 (인증서 관리) **19**

제38조 (시행과 갱신) **19**

제1장 총 칙

제1조 (목적)

본 지침서는 연세대학교 의료원(이하 산하기관을 포함하여 '의료원'이라 칭함)의 의료정보시스템 개발 시 보안기능이 적절하게 구현되고, 개발 담당자의 보안관리가 충분히 이루어지게 하는 것을 목적으로 한다.

제2조 (적용범위)

본 지침서는 의료원내의 의료정보시스템, 응용프로그램, 개발 담당자들을 적용범위로 하며, 자원을 이용하거나 정보전달을 행하는 모든 사용자 및 시스템을 대상으로 한다.

제3조 (용어설명)

① 관리자용 계정 : 본 지침서의 관리자용 계정이라 함은 응용시스템을 운영관리 목적으로 생성된 계정을 말한다.

② 개발자용 계정 : 본 지침서의 개발자용 계정이라 함은 응용프로그램 개발, 변경 등의 목적으로 생성된 계정을 말한다.

③ 도메인 계정(AD) : 본 지침서의 도메인 계정(AD)이라 함은 현업 사용자가 그룹웨어, 전자메일 등을 사용하기 위해 생성된 계정을 말한다.

④ 직번 계정(ID) : 본 지침서의 직번 계정(ID)이라 함은 현업 사용자에게 부여된 직원 번호로 u-Severance 응용프로그램을 사용하는 계정을 말한다.

⑤ 바이오정보 : 지문, 얼굴, 홍채, 정맥, 음성, 필적 등 개인을 식별할 수 있는 신체적 또는 행동적 특징에 관한 정보로서 그로부터 가공되거나 생성된 정보를 포함한다.

제4조 (책임과 역할)

① 최고정보보호책임자 : 의료원의 정보시스템 총괄 책임자로서 의료원 정보보호와 개인정보보호 책임자 역할을 겸직 수행한다.

② 정보보호책임자 : 최고정보보호책임자에 의해 위임된 정보보호 업무를 수행한다.

③ 정보보호관리자 : 각 부서장으로서 부서의 정보보호와 개인정보보호를 직접 수행하며 부서 보안사고에 대한 책임을 진다.

④ 정보보호실무책임자 : 정보보호 주관 부서장으로서 전사적인 정보보호와 개인정보보호 정책 수립 및 이행하며 정보보호관리자(각 부서장)의 정보보호 활동을 지원한다.

⑤ 정보보호 및 보안 실무담당자 : 정보보호실무책임자가 임명한 정보보호 및 개인정보보호 업무 담당자로서 의료원 정보보호 및 개인정보보호를 위한 관리적/물리적/기술적 부문에서 각 부서의 관련 제반 업무를 지원하며 본 지침서의 이행 점검을 수행한다.

⑥ 부서 정보보호담당자 : 정보보호관리자(각 부서장)이 임명한 부서의 정보보호담당자로서 의료원 정보보호 정책이 이행될 수 있도록 부서 내에서 정보보호 업무를 성실히 수행한다.

⑦ 시스템운영관리자 : 정보시스템 운영 부서의 운영 책임자로서 해당 부서의 부서장(팀장)을 의미하며 의료원 업무 정보시스템이 보안사고를 미연에 방지하기 위한 필요한 조치를 취할 책임과 권한을 가진다.

⑧ 개발담당책임자 : 의료정보 응용프로그램 개발업무 담당 파트장으로 의료원 보안사고를 미연에 방지하기 위한 개발단계에서 보안관리에 필요한 조치를 취할 책임과 권한을 가진다.

⑨ 개발담당자 : OCS/EMR, PACS, 그룹웨어 등 응용프로그램 및 홈페이지 개발 업무 수행하는 담당자로서 외주 용역업체 보안관리와 소스코드 보안 등을 포함하여 개발보안관리를 위한 필요한 조치를 취한다.

⑩ 응용시스템운영담당자 : OCS/EMR, PACS 등의 의료정보시스템과 그룹웨어, 홈페이지 서버 등의 운영 담당자로 응용프로그램이 안전하고 안정되게 운영되도록 필요한 조치를 취한다.

⑪ 사용자 : 직번 계정(ID)과 도메인 계정(AD)을 부여받아 정보시스템에서 제공하는 서비스를 이용하여 업무를 처리하거나 정보를 획득하는 자로서 의료원 교직원뿐 아니라, 파견업체나 협력업체 등 외부자를 포함하며, 사용자는 의료원의 정보자산을 보호하고, 정보보호 규정 및 지침서를 성실히 준수해야 할 의무를 갖는다.

제2장 개발 보안 관리

제5조 (보안요구사항의 검토)

① 정보시스템 도입과 확장을 추진하기 위해서 정보보호 담당부서는 보안 요구사항 분석 및 상세화 절차를 검토한다.

1. 보안 통제 사항 구현을 위한 시스템의 지원 여부
2. 보안 기능의 부재 또는 실패 시에 잠재적인 업무 손상 정도
3. 관련된 자산의 업무적 가치(중요성)

② 법률적 요구사항 및 정보보안 요구사항 식별

1. 개발담당자는 응용시스템이 다루는 정보자산의 처리와 관련한 법률적인 요구사항을 식별한다.
2. 개발담당자는 응용시스템에 대하여 예상되는 보안 위협과 이의 발생 가능성들을 고려하여 보안 기능 요구사항들을 도출한다.
3. 제안요청서에 제시된 정보보안 요구사항 식별한다.
4. 정보보안 요구사항은 서비스 개발 목적 및 이를 이루기 위한 서비스 관점에서 조사한다.

제6조 (정보시스템의 개발요구 분석 및 보안적용)

① 정보시스템을 개발하기 위한 업무 요구사항 명세서에는 보안통제를 위한 분석이 포함되어 설계되어야 한다.

② 개발담당책임자는 필요한 보안 기능을 정하고 각 개발 단계 별 정보보호실무책임자와 적용해야 하는 보안 기능에 대하여 협의할 수 있다.

제7조 (입력 데이터 검증)

① 응용프로그램에 대한 입력데이터는 정확하고, 적절한가를 검증한다.

1. 입력데이터는 각 프로그램의 필드의 성격에 따라 적절하게 검증되어야 한다.
2. 유효성의 오류를 정의한 지침서를 마련하며 테스트 수행 시 다음과 같은 내용이 포함되어야 한다.
   i. 한계 값을 넘는 값의 입력
   ii. 데이터 영역에 잘못된 문자의 입력
   iii. 불완전한 데이터의 입력
   iv. 데이터의 크기가 메모리 할당 범위를 벗어난 입력

제8조 (프로그램의 처리절차)

① 처리오류 및 고의적인 행위를 통한 정보의 변조를 탐지하기 위해 유효성 점검기능이 응용프로그램 내에 구현되어야 한다.

② 자료를 변경하기 위한 추가, 정정, 삭제기능의 권한이 개인별로 설정되어야 한다. (사용자 계정 등록 시에 자료의 권한설정 부여)

③ 잘못된 순서로 실행되거나 전처리가 성공하지 못한 경우에도 실행되는 현상을 막을 수 있는 조치가 있어야 한다.

제9조 (출력자료의 검증)

① 응용프로그램의 자료 출력은 저장된 자료처리가 정확하고, 환경에 적절하게 처리되었음을 검증한다.

1. 출력자료가 타당한지 시험한다.
2. 모든 자료의 처리가 확실하게 보안통제정책과 일치하는 지를 확인한다.

제10조 (환경 분리)

① 개발 및 테스트시스템과 운영시스템은 분리하는 것을 원칙으로 한다.

② 개발 및 테스트시스템에 접근통제를 구현한다.

③ 운영시스템에서 테스트 수행을 금한다.

④ 응용시스템을 테스트할 때, 임의의 테스트 데이터를 생성하여 활용하거나 운영 데이터를 가공 또는 암호화하여 사용하도록 하며 실제 운영 데이터의 사용은 금한다. 단, 부득이 한 경우 별도의 보안대책을 수립하여 사용할 수 있다.

⑤ 사안에 따라 개발담당자들이 개발업무를 수행하기 위한 공간은 논리적으로 내부망과 분리된 별도의 네트워크 망 사용하도록 관리(VLAN 구성 등)할 수 있다.

제11조 (운영 소프트웨어의 통제)

① 운영 소프트웨어, 응용프로그램, 응용프로그램 라이브러리의 갱신은 해당 업무 담당자가 부서장의 승인을 받고 실행한다.

② 응용프로그램과 운영 소프트웨어는 광범위하게 테스트가 성공적으로 실행된 다음에 적용한다.

1. 적용된 프로그램은 변경이 이루어지기 전의 상황으로 되돌릴 수 있는 처리절차가 준비되어야 한다.
2. 모든 운영프로그램 라이브러리 변경에 관한 기록은 버전별로 변경된 사항을 관리한다.
3. 이전 버전의 프로그램은 비상조치로서 유지, 보관한다.

제12조 (프로그램 소스에 대한 접근통제)

① 프로그램 소스에 대한 접근은 엄격히 통제한다.

② 프로그램 소스 라이브러리를 변경하거나 프로그램의 수정사항이 있을 시 개발담당자는 적절한 인가 후에 작업을 실행한다.

③ 프로그램 소스는 보안구역에서 관리되어야 하며, 외부유출을 금한다.

④ 모든 프로그램 소스 라이브러리의 수정 및 추가 기록은 내용을 파악할 수 있도록 변경이력이 관리되어야 한다.

⑤ 소스코드는 실제 운영 환경에 보관하지 않으며, 소스코드 관리 담당자는 각 운영 시스템

별로 지정하고, 소스코드에 대한 접근은 정보보호관리자(소속 부서장)의 허가를 득한다.

1. 프로그램 소스코드는 운영중인 시스템에 저장하여 관리하는 것을 금한다.
2. 담당 부서장은 개발담당자 및 응용시스템운영담당자가 프로그램 소스코드에 접근하는 것을 적절히 통제하고, 접근 기록을 남긴다.

제13조 (안전한 프로그래밍)

① 개발담당책임자는 응용시스템 개발에 적합한 언어를 선택할 때 개발 언어의 보안성을 고려하고, 각 개발 언어의 보안상 알려진 취약점에 대해 개발담당자들에게 숙지시켜야 한다.

② 개발담당책임자는 외주를 이용한 소프트웨어 개발 시 위험요소를 파악하고 보안통제를 시행하여야 하며 이에 관한 통제는 '외주용역 보안관리 지침서'를 참고한다.

제14조 (외주 소프트웨어의 개발)

① 외주를 통한 소프트웨어 개발은 반드시 해당 부서의 정보보호관리자(소속 부서장)에 의해 지휘 감독하고, 감시한다.

② 외주용역 당사자는 "인적보안지침서 정보보호서약서"를 제출하여야 하며, 필요에 따라 별도 서약서를 징구할 수 있다.

③ 라이센스 협정, 프로그램 소스코드에 대한 소유권 및 지적재산권에 대한 협약 내용을 확인해야 하며 이를 계약서 상에 명기한다.

④ 개발된 프로그램의 질적 수준 및 자료처리의 정확도를 보장한다.

⑤ 개발 완료된 프로그램의 품질 및 사용자 접근권한 처리를 확인한다.

⑥ 개발자는 개발매체에 악성코드 및 바이러스가 감염되지 않도록 주기적으로 바이러스 검사를 시행한다.

제15조 (의료기관 간 교환협정)

① 진료 정보 등을 타 병원(조직)과 교환할 경우 데이터 보호 및 손실 등의 보안사고 발생 시

책임 등에 대한 교환협정을 체결한 후 교환하여야 하며, 확인 사항은 다음과 같다. 단, 의료원 산하 기관과의 교환은 예외로 한다.

1. 전달, 발송 및 수령을 통제하고 통지하는 관리 책임
2. 발송자, 전달, 발송 및 수령을 통하는 절차
3. 추적이 가능한 부인방지가 보장된 절차
4. 정보를 유실하는 정보보안 사안에 대한 책임과 의무
5. 자료의 보호, 소프트웨어 저작권, 소프트웨어 라이센스 준수 및 소프트웨어 소유권과 책임

제16조 (진료 정보 등의 교환방법)

① 통신 기기를 통해 이루어지는 정보 교환에 대해 보호하는 정책, 절차, 방안을 수립한다. 단, 의료원 산하 기관과의 교환과 공공 및 정부 기관의 환경에 따라 예외로 할 수 있다.

1. 교환된 정보를 보호하기 위해 자료의 무결성을 보장하는 대책을 수립한다.
2. 악성코드 탐지와 방지를 위한 절차를 수립한다.
3. 첨부물 형식으로 의료정보를 전달하는 절차를 수립한다.
4. 전자통신장치의 사용법에 관한 정책과 지침을 마련하여야 하며, 이는 “네트워크 보안 지침서” 및 “문서 및 매체 보안관리 지침서”, ”사용자 보안관리 지침서”를 따른다.

제3장 응용시스템 보안관리

제17조 (관리자용 및 개발자용 계정관리)

① 관리용 계정은 관리자용 계정과 개발자용 계정으로 구분한다.

② 응용시스템의 관리자용 및 개발자용 계정은 1인 1계정을 원칙으로 한다.

③ 응용시스템운영담당자의 신규 관리자용 및 개발자용 계정 등록 시 “[별지 제1호 서식] 투입인력(장비) 신고 및 자원 요청서”를 작성하여 시스템운영관리자에게 제출한다.

④ 응용시스템운영담당자는 “[별지 제2호 서식] 관리용 계정(ID) 관리 대장”에 관리자용 계정 및 권한 내역을 기록하며, 시스템운영관리자는 정기적으로 점검, 확인한다.

⑤ 용역사업 개발자에게 직번 계정(ID) 발급 시 단순 조회만 가능하도록 해야 한다. 단, 업무에 따라 필요 권한을 부여할 수 있다.

⑥ 응용시스템운영담당자는 투입인력 철수 시 “[별지 제6호 서식] 투입인력(기술지원, 유지보수) 철수 확인서”를 작성하여 시스템운영관리자에게 제출한다.

제18조 (현업 사용자 계정 관리)

① 현업 사용자 계정은 도메인 계정(AD)과 직번 계정(ID)으로 구분한다.

② 도메인 계정(AD) 등록의 상세 절차는 “사용자 보안관리 지침서 제8조 (사용자 계정관리)”를 따른다.

③ 업무 특성 상 임의로 직번 계정(ID)을 발급할 경우 시스템관리자의 승인을 거쳐 해당 부서의 접근권한을 부여한다.

④ 담당 업무가 정해지지 않으나 계정 발급이 필요한 경우 응용시스템의 접근권한은 최소로 설정한다.

제19조 (비밀번호 관리)

① 관리용 및 도메인 계정(AD), 직번 계정(ID)의 비밀번호 생성 및 관리의 기준은 “사용자 보안 관리 지침서/제12조(사용자 암호 사용 및 비밀번호 관리)”를 따른다.

② 도메인 계정(AD)과 직번 계정(ID)에 대한 비밀번호 관리는 다음을 따른다.

1. 신규 발급 시 또는 분실 처리 시 부여되는 초기 비밀번호와 임시 비밀번호도 지침 기준에 부합되도록 한다.
2. 초기 비밀번호, 임시 비밀번호는 최초 로그인 시, 반드시 변경하여야 하며, 90일마다 1회 주기로 변경될 수 있도록 유도한다.
3. 최근 비밀번호 이력을 보관하여, 재사용할 수 없도록 한다.
4. 비밀번호는 암호화하여 저장하며, 원칙적으로 복호화 할 수 없도록 한다.

제20조 (업무용 사용자 접근권한 관리)

① 응용시스템의 접근권한은 인원별 또는 접근권한별 권한 부여 현황 및 주요 접근권한에 대한 적정성 검토가 이루어져야 한다.

② 응용시스템에 대한 접근통제를 위해 다음사항을 준수하여 접근권한 관리를 실시한다.

1. 업무조직 및 역할을 고려해 응용시스템 사용자들의 접근권한을 설정하고, 정보보호관리자(소속 부서장)의 승인을 득한다.
2. 응용시스템에 접속한 후 일정시간 동안 어떤 입력도 일어나지 않을 경우 자동적으로 세션을 중단시키도록 시스템을 설정하는 것을 원칙으로 한다.
3. 시스템운영관리자는 사용자 계정 및 권한을 주기적으로 검토하고, 퇴직, 부서이동, 계약종료 등 변동 사항 발생 시 즉시 해당 계정을 삭제하거나, 권한을 조정한다.

제21조 (업무용 사용자 접근 및 사용 통제)

① 연속 5회 이상 반복적인 로그인 실패 시 해당 계정 사용자에게 고지하며, 필요에 따라 시스템운영관리자는 사용자 계정을 중지시킬 수 있다.

② 서로 다른 IP로부터 동일한 계정으로의 로그인을 시도하는 경우, 중복적인 로그인을 허용하지 않아야 하며, 중복 로그인 발생에 대한 메시지를 출력하여 계정 도용 시도 등에 대한 인지가 가능하도록 한다. 단, 수술, 환자관리 등의 병원 업무(OCS/EMR 등) 사용의 필요성이 인정되는 경우 예외로 할 수 있다.

③ 응용시스템에 로그인 후 일정기간 동안 시스템을 사용하지 않을 경우 자동으로 로그아웃되도록 하여, 사용자의 이석으로 로그인 세션이 방치되는 경우 발생할 수 있는 시스템의 비인가 접근 가능성을 최소화한다. 단, 수술, 환자관리 등의 병원 업무로 필요성이 인정되는 경우에는 예외로 할 수 있다.

제22조 (응용 서비스 접근통제)

① 네트워크에 공개된 응용서비스는 시스템 자체의 외부접속 차단 방화벽 또는 네트워크

경로의 방화벽에 의해 접근통제를 적용한다.

② 보안성 검토 승인 절차를 거치지 않은 모든 응용서비스는 방화벽에 의해 외부망으로부터의 접속을 차단한다.

③ 데이터 내용에 대한 도청 가능성이 존재하는 telnet(23) 등의 서비스는 방화벽에서 접속을 차단하고 ssh(22)를 허용한다.

④ 원격 접속이 필요한 서비스에 대해 원격 접속 호스트의 IP만 허락한다.

⑤ 웹 서비스 등과 같이 불특정 다수에게 서비스할 경우에는 해당 서비스 포트만 허락한다.

제23조 (화면 표시 제한)

① 사용자가 접근권한을 갖지 않는 정보나 기능 등은 화면에 표시되지 않도록 하여, 불필요한 정보의 제공이나 우회 접근 시도의 가능성을 제거한다.

② 주민등록번호, 카드번호 등의 민감한 정보는 입력이나 조회 화면 또는 출력 시 부분 정보만을 표시하여야 하며, 비밀번호는 전체 정보에 대해 마스킹 처리한다. 단, 업무 특성상 조회가 정보 표시가 필요한 경우에 한해 예외로 할 수 있다.

③ 화면에서 제공하는 정보의 양을 적절히 통제하고, 소스 보기 등의 기능 사용 통제, 다운로드 기능 제공 최소화 등을 통하여 우회적인 방법으로 대량 정보를 획득할 수 있는 가능성을 최소화한다.

제24조 (의료정보시스템의 변경 통제 절차)

① 정보시스템의 변경은 공식적인 변경절차에 따라 통제되어야 한다.

② 변경 승인한 문서기록은 유지한다. 응용시스템운영담당자는 “[별지 제3호 서식] 변경요청서”를 작성하여 시스템운영관리자에게 보고한다.

③ 인가된 사용자에 의해 변경이 이루어져야 하며, 시스템의 변경사항인 경우 해당 소프트웨어 설치업체나 벤더에서 파견된 기술자가 변경하도록 한다.

④ 수정을 요구하는 모든 소프트웨어, 정보, 데이터베이스 관계도 및 하드웨어를 파악한다.

⑤ 변경이 완료된 후 관련 문서는 변경되어야 한다.

제25조 (운영체제의 변경(patch update)에 따른 어플리케이션 검토)

① 운영체제가 변경되었을 경우 운영 및 보안측면에서 영향이 없다는 것을 확인하기 위하여 중요 응용프로그램은 테스트되어야 한다.

② 운영체제의 변경에 의해 응용프로그램을 재 컴파일 해야 하는 등 손상이 없다는 것을 확인한다.

③ 운영체제가 변경된다는 것을 적시에 통보 받아 적절한 시험 및 검토가 이루어질 수 있도록 한다.

④ 운영체제의 변경으로 인하여 업무 연속성에도 변경이 있을 수 있음을 확인한다.

제26조 (응용시스템 백업)

① 응용시스템의 물리적 장애 또는 천재지변 등 비상사태에 대비하여 백업을 한다.

② 응용시스템 파일의 중요도에 따라 백업 정책을 수립한다.

③ 백업 매체를 생성하여 백업하는 경우는 다음을 따른다.

1. 백업 매체 보관 시 저장 장소는 잠금 장치가 있는 캐비닛이나 내화금고에 보관한다.
2. 정기적으로 복사본을 생성하여 원격지나 재해복구센터에 보관한다.
3. 백업데이터의 보관 주기는 규정한 보존기한을 따른다.
4. 중요 백업 내용들은 정기적으로 검증을 실시한다.

제27조 (응용시스템 복구)

① 응용시스템 장애 시에는 백업 매체와 로그 테이프(또는 백업 디스크)를 사용하여 복구한다.

② 디스크 장애에 대비하기 위하여 중요 응용시스템은 디스크를 이중화 한다.

③ 시스템운영관리자 및 응용시스템운영담당자는 작성된 장애 기록을 보관하고, 장애 예방자료 및 장애 발생시 참고자료로 이용 가능하도록 조치한다.

제28조 (로그 및 모니터링)

① 전산 자료를 처리하는 응용시스템의 가동 기록은 아래 ②, ③항에 제시된 항목을 포함하여 2년 이상 보존한다.

② 로그 데이터가 충분히 남겨질 수 있도록 저장 공간을 확보한다.

③ 사용자의 시스템 접근 및 사용 내역은 감사 추적을 위해 기록, 관리되어야 한다.

1. 응용시스템에 대한 접근권한 부여 및 회수 등 계정 관리의 적정성을 검토하고 확인할 수 있도록 계정 관리에 대하여 다음의 로그를 기록한다.

   i.사용 계정명

   ii.로그인/아웃 일시

   iii.접속 IP 주소

   iv.쿼리문

   v.응답시간 및 실행시간

   vi.결과값

2. 기밀 또는 고객정보에 해당하는 정보자산에 대한 입력, 조회, 수정, 삭제 등의 사용 내역 확인을 위하여 로그를 기록한다.

④ 응용시스템운영담당자는 주기적으로 로그를 점검하여 이상유무를 확인한다.

⑤ 로그 파일은 노출, 변조 또는 삭제되지 않도록 불필요한 접근으로부터 보호한다.

⑥ 운영담당자는 운영환경에 대해 지속적으로 모니터링을 실시한다.

제29조 (장애 관리)

① 응용시스템 장애 발생 시 “장애 유형별 장애 처리 가이드”에 따라 처리한다.

② 응용시스템 장애 발생 시 동일한 사고의 반복을 방지하고, 장애 발생 시의 신속한 복구를 원활히 하기 위해 다음의 내용을 포함한 “[별지 제4호 서식] 장애 발생 보고서”를 작성하여 시스템운영관리자에게 보고한다.

제30조 (가용성 및 무결성 확보)

① 네트워크를 통해 직접 파일 접근이 가능한 공개된 응용시스템의 주요 파일 및 디렉토리 등에 대한 무결성 점검을 수행한다.

② 무결성 점검은 정기적으로 수행하고, 보안 사고 발생시 운영관리자는 즉시, 보고서를 작성하여 정보보호관리자(소속 부서장)에게 제출 및 보고한다.

③ 외부 인터넷에 공개된 파일들의 무결성 침해사고 시에 정보보호관리자(소속 부서장) 및 정보보호실무책임자와 협의 후 해당 파일의 원본 또는 백업 파일을 즉시 복원한다.

④ 복원시 운영관리자는 무결성이 침해된 것으로 확인된 파일, 연관 파일 또는 디렉토리 전체를 프로세스 구동이 금지된 안전한 저장공간에 백업해서, 침해사고 분석자료를 확보한다.

제31조 (기술적 취약점 통제)

① 사용 중인 의료원 정보시스템의 기술적 취약성에 대한 정보는 적시에 획득하고, 취약성 평가 및 제거 등 적절한 관리활동을 한다.

② 의료원은 기술적 취약성의 감시, 위험평가, 패치, 자산추적, 업무의 상호협동에 대한 책임과 역할을 명시한다.

③ 개발담당책임자는 안전행정부에서 발행한 '시큐어 코딩 가이드'를 참고하여 반기 1회 이상 자체 교육을 실시한 후 “[별지 제5호 서식] 교육 참석자 확인서"를 작성하여 정보보호실무책임자에게 보고한다.

④ 만일 패치적용이 가능하다면 패치를 적용함으로써 발생할 위험은 미리 파악되어야 한다.

⑤ 패치는 적용되기 전에 시험 적용되어야 하며, 설치된 후에는 역효과가 없음을 확인한다.

⑥ 패치적용이 불가능하다면 다음과 같은 사항을 고려하여 수행한다.

1. 취약성에 노출된 서비스를 차단한다.
2. 접근통제를 적용하거나 추가한다.
3. 방화벽 정책을 추가하거나 방화벽을 증설하는 방법을 강구한다.
4. 실제적인 공격을 예방하고, 색출하기 위해 모니터링을 강화한다.
5. 취약성에 대한 인식을 더 강화시키고, 해당 내용을 공유한다.

제4장 암호화 및 인증서 관리

제32조 (암호화 요구)

① 전산장비 및 저장매체에 보관하고 있는 기밀유지에 필요한 정보는 암호화하여 보관한다.

② 보안위험을 대비하기 위해 암호화, 전자서명, 인증 등의 대책이 적용되어야 한다.

1. 고객 정보, 인증 정보, 전자상거래 시의 거래 정보 등을 보호되지 않은 외부 네트워크를 통해 전송할 경우에는 암호화하여 전송한다.
2. 비밀번호, 주요 고객 정보(주민등록번호, 외국인등록번호, 여권번호, 운전면허번호 등), 바이오정보는 암호화하여 저장한다. 단, 비밀번호의 경우에는 복호화 할 수 없도록 일방향 암호화하여 저장한다.

③ 암호화 프로그램 적용과 키 생성 및 배포 관리는 별도의 암호담당자를 지정하여 통합 관리하며, 보관은 통제구역 내의 내화금고에 보관 관리한다.

④ 암호 프로그램의 소스는 별도로 내화금고에 보관하여야 하며, 복사된 기록매체는 비밀문서에 준하여 관리한다.

⑤ 암호화와 복호화가 동일프로그램에서 이루어지도록 구성하지 않는다.

제33조 (암호사용에 관한 정책)

자료의 중요도에 따라 암호화 정책을 적용할 수 있다.

① 기밀성이 요구되는 DB시스템 내의 중요 필드(주민등록번호, 외국인등록번호, 여권번호, 운전면허번호, 비밀번호, 바이오정보 등)는 암호화하여야 한다.

② 암호화된 주요 정보는 백업 시에도 암호화 상태를 그대로 유지하여야 한다.

③ 안전성이 검증된 암호화 알고리즘을 사용하여야 한다.

구분	공공기관	민간부문(법인·단체·개인)
대칭키 암호 알고리즘	SEED, LEA, HIGHT, ARIA-128/192/256	SEED ARIA-128/192/256 AES-128/192/256 Blowfish Camelia-128/192/256 MISTY1 KASUMI 등
공개키 암호 알고리즘 (메시지 암·복호화)	RSAES-OAEP	RSA RSAES-OAEP RSAES-PKCS1 등
일방향 암호 알고리즘	SHA-224/256/384/512	SHA-224/256/384/512 Whirlpool 등

제34조 (네트워크 암호화)

① 개인건강정보 등 민감한 정보를 네트워크로 송・수신 할 경우에는 자료를 암호화하거나 구간 암호화 통해 기밀성을 유지한다. 단, 시스템 연동으로 관련 정부기관이나 공공기관으로 정보를 제공하는 경우와 해당 기관의 환경에 따라 예외로 할 수 있다.

제35조 (암호화 및 키 관리)

① 정보보호를 위한 암호화 및 키 관리 시 다음을 준수한다.

1. 암호 알고리즘과 키는 담당자 이외에 정보시스템 운영자를 포함한 어떠한 직원에게도 유출되어서는 안 된다.
2. 암호화 키의 길이가 적절하고 충분해야 한다.
3. 암호화 키는 암호화한 데이터와 물리적으로 분리하여 저장하거나 별도로 암호화하여 비인가 접근으로부터 보호한다.
4. 암호화 키를 분실하는 경우에 대비하여 암호화 키를 복구할 수 있는 대응책을 수립하여야 하며, 이를 위해 별도의 암호화 키 백업을 유지하는 경우 해당 백업본에 대한 비인가 접근이 발생하지 않도록 관리한다.
5. 암호화 키의 사용기간은 최대 2년, 유효기간은 최대 5년을 권고하고 있으나 암호화

키 변경 시 비용과 정보자산 및 업무 중요도를 고려하여 자체적으로 정하여 적용할 수 있다.

제36조 (암호화 프로그램 관리)

① 암호화 프로그램의 소스는 대외비로 관리하며 업무프로그램과 분리하여 보관한다.

② 암호화 프로그램은 대외비 등록절차에 의거 등록한다.

제37조 (인증서 관리)

① 인증서는 유효기간이 만료되기 전에 갱신하여 인증서비스의 연속성을 보장한다.

② 사용자는 인증서 개인키가 분실, 훼손, 도난, 유출되지 않도록 유의한다.

③ 기타 인증서 관리는 "해당 공인인증센터"의 정책을 준용한다.

제38조 (시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 '제4장 정보보호 정책'에 준한다.

[별지 제 1 호 서식] 투입인력(장비) 신고 및 자원 요청서

투입인력(장비) 신고 및 자원 요청서

1. 기본사항

소속(회사명)	의료정보팀	직 위	
성 명		연 락 처	
프로젝트명		담당업무	
업무파트명		작성일자	
투입예정기간	20 년 월 일 ~ 년 월 일		

2. 장비 신고사항(SM 및 외부 인력)

NO	전산 장비 신고 항목	수량	비고
1	PC		
2	모니터(inch)		
3	노트북		
4	기타( )		

3. 응용 프로그램 관리용 계정

NO	시스템 명	Check	사용권한	계정	비고
1	u-Severance				
2	ERP				
3	기타( )				

4. 요청사항

NO	항목	Check
1	IP Address	
2	VPN 계정	
3	e-mail 계정	
4	VDI 계정	
5	전화기	
6	정맥인식 등록	
7	TFS 계정	

NO	항목	Check
8	Visual Studio 설치	
9	MS SQL 설치	
10		
11		
12		
13		
14		

위와 같이 연세의료원에서 20 년 월 일부로 업무를 수행하고자 하오니 승인하여 주시기 바랍니다.

의료정보팀	신청자	파트장/PL	팀 장	소 장

[별지 제2호 서식] 관리용 계정(ID) 관리 대장

관리용 계정(ID) 관리대장

번호	사원 번호	이름	IP 주소	ID	등록 일자	종료 일자	사용권한	비고

[별지 제3호 서식] 변경 요청서

변 경 요 청 서(SP,응용프로그램)

설계자	파트장/PL	팀장	소장

요청일시 : 2025-04-04 17시 28분

1. 배포구분	(□정기/□비정기/□긴급주간/□긴급야간)	긴급배포사유		현재 장애정도	□시스템전체/□단위업무전체/□특정기능
2. 업무구분	□공통 □원무 □진료 □EMR □진료지원 □기타( )	단위업무		운영 적용예정일시	2025-04-04 18:30

3. 작업내용(상세기술)

NO	Stored Procedure	프로젝트(Assembly)	내 용	화면명/기능	CSR	요청자	신촌/강남/공통
1							
2							
3							
4							
5							
6							
7							
8							
9							
10							
11							
12							

4. C# 소스 점검

소스Check-IN(일자)	
TFS Reference Check-IN	□Y / □N
F/S DLL Copy	□Y / □N

* 파일서버 Copy확인후 요청서 제출

5. 테스트 / 이관 (서명/시간)

서버	담당	사인	일시
개발	설계자		/ , :
교육	DBA		/ , :
	Architect		/ , :
	파트장		/ , :
운영	DBA		/ , :
	Architect		/ , :

6. 강남(신촌) 테스트 및 배포상태

서버	담당	배포확인	일시
개발		□강남 (신촌)개발 배포확인	/ , :
			/ , :
			/ , :
교육		□강남 (신촌)교육 배포확인	/ , :
			/ , :
			/ , :

7. 관련파트 확인요청

파트명	파트장/PL
원무	
진료	
EMR	
진료지원	
DW	
Table변경,기타관련파트확인	

NO	Stored Procedure	프로젝트(Assembly)	내 용	화면명/기능	CSR	요청자	신촌/영동/공통
13							
14							
15							
16							
17							
18							
19							
20							
21							
22							
23							
24							
25							
26							
27							
28							
29							
30							
31							
32							
33							

[별지 제4호 서식] 장애 발생 보고서

담 당	파트장	팀 장	소 장	실 장

장애발생 보고서(App./System)

제 목			
장애 일시		조치 일시	
작 업 자	정보서비스팀		
	정보보안팀		
장애 내용			
장애 접수 및 경과 조치			
장애 원인			
재발 방지 및 조치 계획			

[별지 제5호 서식] 교육 참석자 확인서

교육 참석자 확인서

- 교육명 :
- 강사명 :
- 교육일자:
- 교육시간 :

번호	소속	직번	성명	서명

[별지 제6호 서식] 투입인력(기술지원, 유지보수) 철수 확인서

투입인력(기술지원,유지보수) 철수 확인서

1. 기본사항

소속(회사명)		직 위	
성 명	(인)	연 락 처	
프로젝트명		담당 업무	
업무파트명		작성 일자	20 년 월 일
투입기간	20 년 월 일 ~ 20 년 월 일		

2. 점검사항

NO	점검 항목	확인파트	확인자	확인 Sign	비고
1	IP / OTP 반납	네트웍관리	김종명		IP: OTP:
2	e-mail ID 삭제	네트웍관리	정충모		ID:
3	VDI 계정 삭제	네트웍관리	임송태		
4	PC/노트북 포맷	정보보안			
5	퇴직자 보안 서약서 작성 확인	정보보안			
6	전화기/번호 반납	정보통신			TEL :
7	의료원 대여장비 반납	아키텍쳐	박재현		
8	TFS ID 삭제	아키텍쳐	박재현		
9	정맥인식 ID 삭제	진료지원	박형철		
10	업무인수인계 확인서 확인	담당파트			

본인은 위와 같이 철수에 필요한 사항을 항목별 관련 담당자에게 점검을 완료하였기에 20 년 월 일부로 연세의료원에서 철수하고자 하오니 승인하여 주시기 바랍니다.

의료정보팀	담당	파트장	소 장

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM